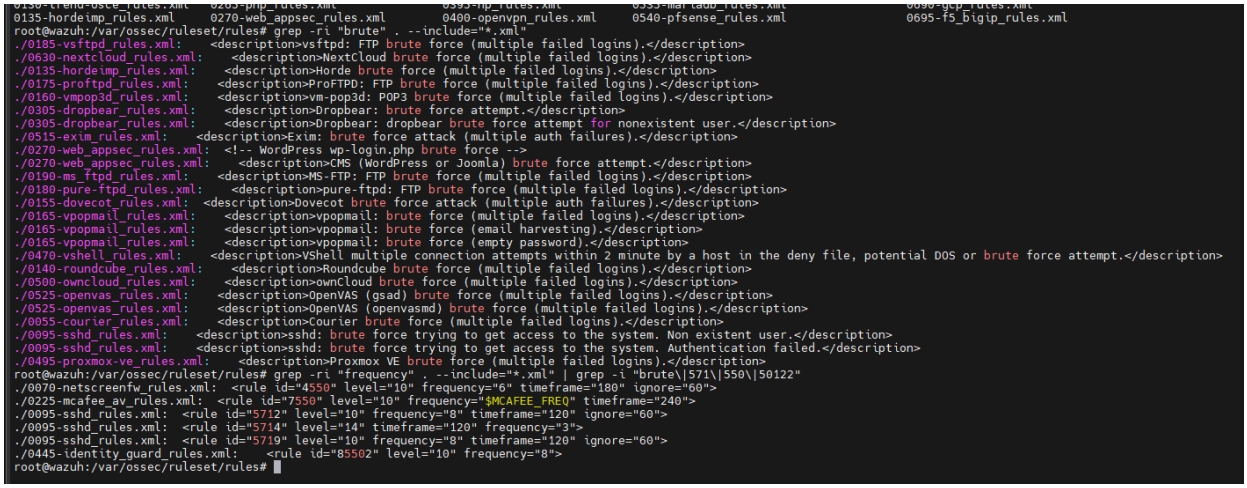
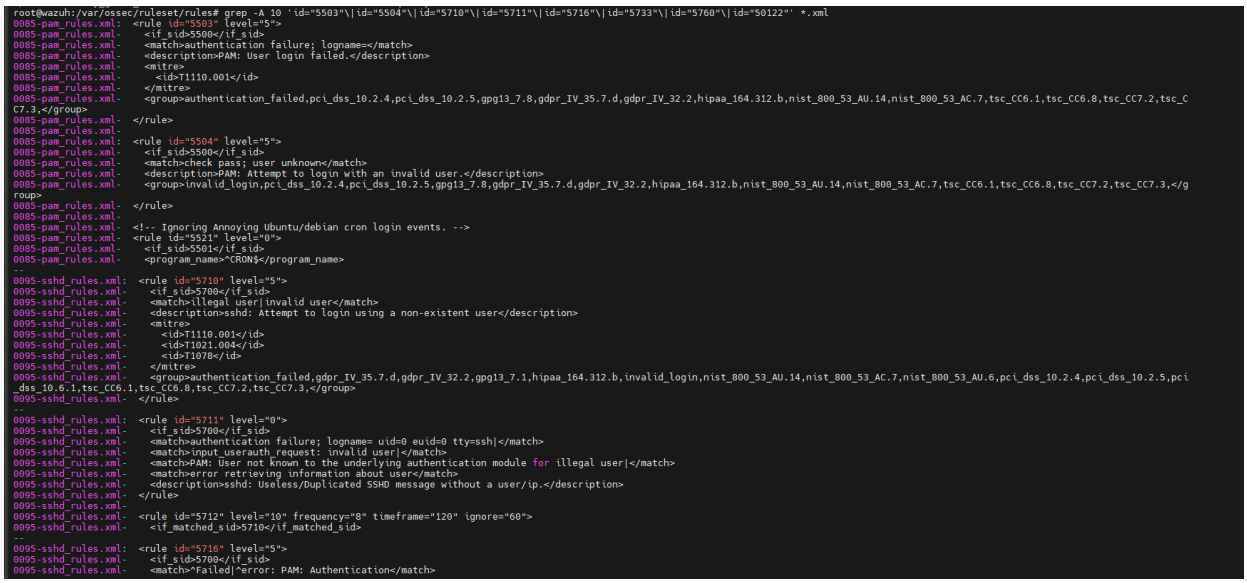
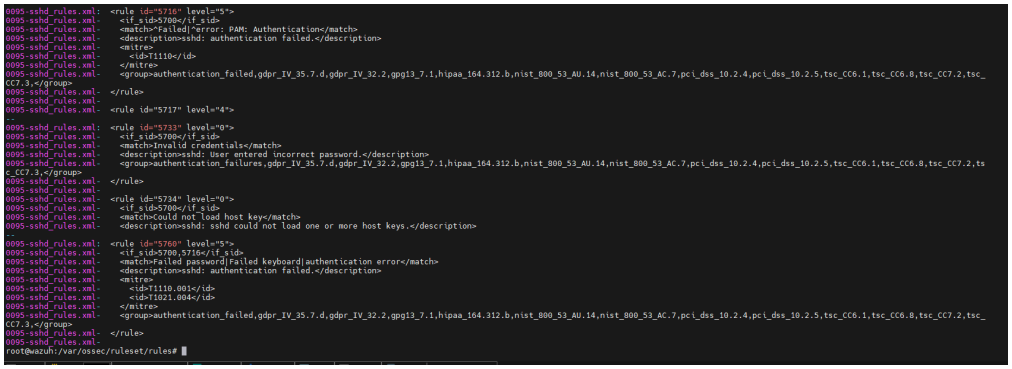
Задание 1. Анализ правил корреляции (rules), относящихся к brute force

Подключаемся к серверу Wazuh и находим правила по умолчанию







Анализ найденных правил brute force

Найденные правила brute force

Rule ID	Файл	Frequency	Timeframe	Описание
5712	0095-sshd_rules.xml	8	120	SSH brute force (multiple failed logins)
5714	0095-sshd_rules.xml	3	120	SSH brute force (альтернативное правило)
5719	0095-sshd_rules.xml	8	120	SSH brute force (duplicate)
5503/5504	0085-pam_rules.xml	—	—	Базовые события неудачной аутентификации (без корреляции)

Главное:

Правило 5714 уже имеет frequency="3" — это исключение из общего шаблона frequency=8. Однако его timeframe=120 всё ещё попадает в список "запрещённых" значений (120, 180, 240).

Выявленный пробел в покрытии

Use Case: Медленный распределённый брутфорс (T1110.003)

Проблема: Существующие правила требуют 8 событий от одного источника за 2-4 минуты. Атакующий может обойти это, используя:

- Ботнет из 10+ источников
- По 1 попытке с каждого источника
- Интервалы между попытками > 60 секунд
- Целевой аккаунт: admin, root, student

Результат: С одного источника не набирается frequency=8, правило не срабатывает.

Предлагаемое решение (Новое корреляционное правило):

```
<rule id="90001" level="14">
  <if_matched_group>authentication_failed</if_matched_group>
  <same_user/>
  <frequency>5</frequency>
  <timeframe>600</timeframe>
  <description>Distributed brute force attempt - multiple sources targeting same user over
extended period</description>
  <group>brute_force,distributed_attack,pci_dss_10.2.4</group>
  <mitre>
    <id>T1110</id>
    <id>T1110.003</id>
  </mitre>
</rule>
```

Чем отличаются новые параметры:

frequency=5 (не 8)
timeframe=600 (не 120/180/240)
Группировка по same_user, а не same_source_ip

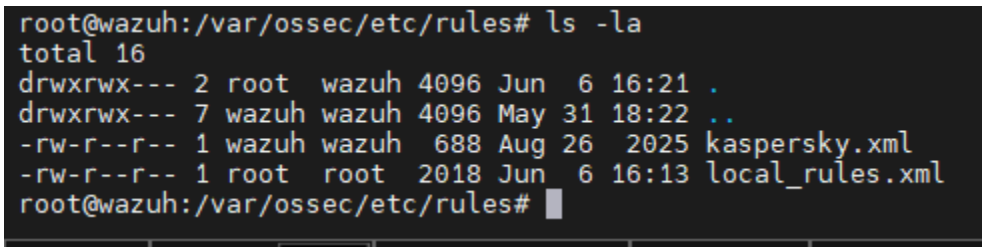
Используемые события/правила (rule IDs):
5503, 5504 — PAM authentication failures (Linux)
5710, 5716, 5760 — SSH authentication failures
50122 — Azure AD / Cloud authentication failures (если применимо)

Почему так:

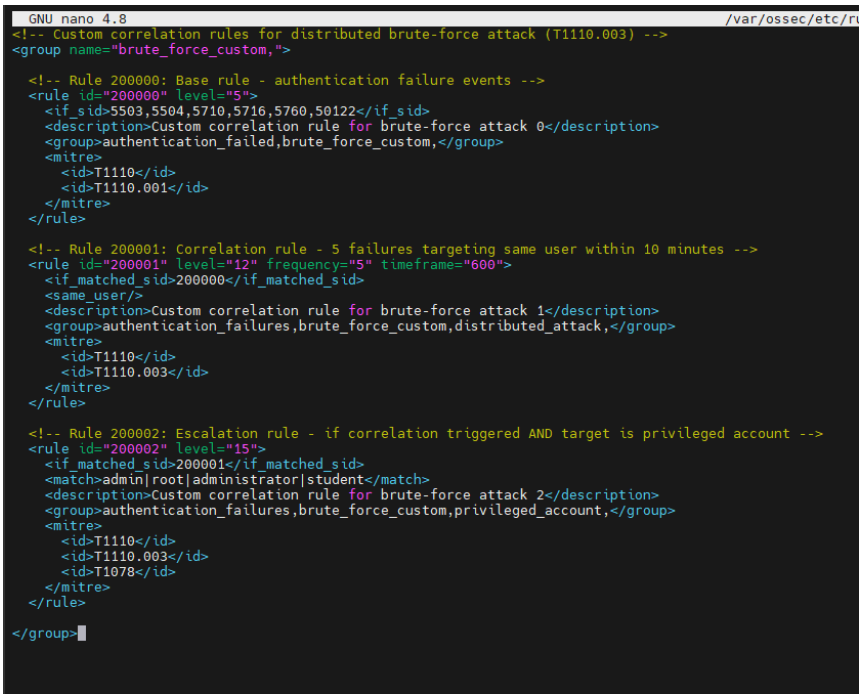
Правило детектирует сценарий Password Spraying (T1110.003), когда атакующий пробует один пароль на множестве аккаунтов или один аккаунт с множества источников. Уменьшение frequency до 5 и увеличение timeframe до 10 минут позволяет выявить медленные атаки, которые иначе остались бы незамеченными. Группировка по same_user фокусируется на защите критичных учётных записей, независимо от количества источников атаки.

Задание 2. Создание новых правил корреляции в Wazuh

Создаем и редактируем файл local_rules



Добавляем в него правила:



Обоснование правил

Параметр	Значение	Обоснование
frequency	5	Достаточно для детектирования, но меньше ложных срабатываний, чем при 8
timeframe	600 (10 мин)	Покрывает медленные атаки с интервалами 60-120 секунд между попытками

<same_user/>	вместо <same_source_ip/>	Детектирует распределённые атаки, когда каждый источник делает 1-2 попытки
level	12/15	Высокий уровень для корреляционных событий, чтобы выделить их в общем потоке

```
root@wazuh:/var/ossec/etc/rules# chown root:wazuh local_rules.xml
root@wazuh:/var/ossec/etc/rules# chmod 0640 local_rules.xml
root@wazuh:/var/ossec/etc/rules# ls -la local_rules.xml
-rw-r----- 1 root wazuh 2018 Jun  6 16:13 local_rules.xml
root@wazuh:/var/ossec/etc/rules#
```

Статус менеджера после перезапуска

```
root@wazuh:/var/ossec/bin# nano /var/ossec/etc/rules/local_rules.xml
root@wazuh:/var/ossec/bin# /var/ossec/bin/wazuh-control restart
2026/06/06 16:30:07 wazuh-analysisd: WARNING: (7617): Signature ID '50122' was not found and will be
wazuh-clusterd not running...
Killing wazuh-modulesd...
Killing wazuh-monitord...
Killing wazuh-logcollector...
Killing wazuh-remoted...
Killing wazuh-syscheckd...
Killing wazuh-analysisd...
wazuh-maild not running...
Killing wazuh-execd...
Killing wazuh-db...
Killing wazuh-authd...
wazuh-agentlessd not running...
wazuh-integratord not running...
wazuh-dbd not running...
wazuh-csyslogd not running...
Killing wazuh-apid...
Wazuh v4.3.11 Stopped
Starting Wazuh v4.3.11...
Started wazuh-apid...
Started wazuh-csyslogd...
Started wazuh-dbd...
2026/06/06 16:30:12 wazuh-integratord: INFO: Remote integrations not configured. Clean exit.
Started wazuh-integratord...
Started wazuh-agentlessd...
Started wazuh-authd...
Started wazuh-db...
Started wazuh-execd...
Started wazuh-analysisd...
Started wazuh-syscheckd...
Started wazuh-remoted...
Started wazuh-logcollector...
Started wazuh-monitord...
Started wazuh-modulesd...
Completed.
root@wazuh:/var/ossec/bin# /var/ossec/bin/wazuh-control status
wazuh-clusterd not running...
wazuh-modulesd is running...
wazuh-monitord is running...
wazuh-logcollector is running...
wazuh-remoted is running...
wazuh-syscheckd is running...
wazuh-analysisd is running...
wazuh-maild not running...
wazuh-execd is running...
wazuh-db is running...
wazuh-authd is running...
wazuh-agentlessd not running...
wazuh-integratord not running...
wazuh-dbd not running...
wazuh-csyslogd not running...
wazuh-apid is running...
root@wazuh:/var/ossec/bin# tail -n 20 /var/ossec/logs/ossec.log | grep -iE "error|critical|rule"
2026/06/06 16:30:21 sca: INFO: Loaded policy '/var/ossec/ruleset/sca/cis_ubuntu20-04.yml'
```

Отсутствие критических ошибок в логах

```
root@wazuh:/var/ossec/bin# tail -n 20 /var/ossec/logs/ossec.log | grep -iE "error|critical|rule"
2026/06/06 16:30:21 sca: INFO: Loaded policy '/var/ossec/ruleset/sca/cis_ubuntu20-04.yml'
2026/06/06 16:30:21 sca: INFO: Starting evaluation of policy: '/var/ossec/ruleset/sca/cis_ubuntu20-04.yml'
2026/06/06 16:30:27 sca: INFO: Evaluation finished for policy '/var/ossec/ruleset/sca/cis_ubuntu20-04.yml'
root@wazuh:/var/ossec/bin# tail -n 20 /var/ossec/logs/ossec.log | grep -iE "error|critical"
root@wazuh:/var/ossec/bin#
```

Что произошло:

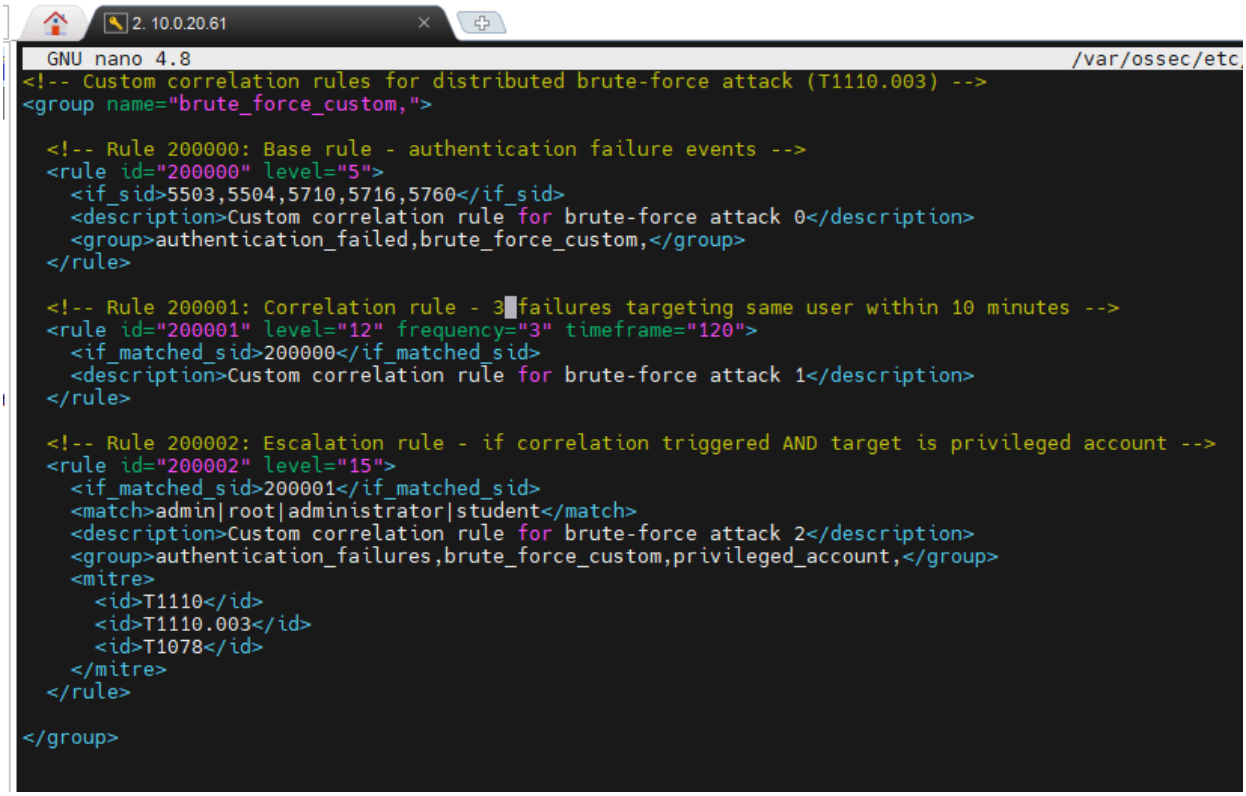
Менеджер запустился — все ключевые службы в статусе running (wazuh-analysisd, wazuh-remoted, wazuh-syscheckd и т.д.).
В логах нет ERROR/CRITICAL — парсинг local_rules.xml прошёл успешно.
Есть одно WARNING (не ошибка).

Итог:

- Корреляционные правила добавлены в /var/ossec/etc/rules/local_rules.xml. Правило 200001 детектирует распределённую атаку brute-force: 5 неудачных аутентификаций на одного пользователя в течение 10 минут (600 сек) с любых источников.
- Параметры frequency=5 и timeframe=600 отличаются от стандартных значений (8 и 120), что позволяет выявлять медленные атаки типа Password Spraying (T1110.003).
- Менеджер Wazuh перезапущен успешно, критических ошибок в логах нет.

Задание 3. Тестирование созданных правил корреляции

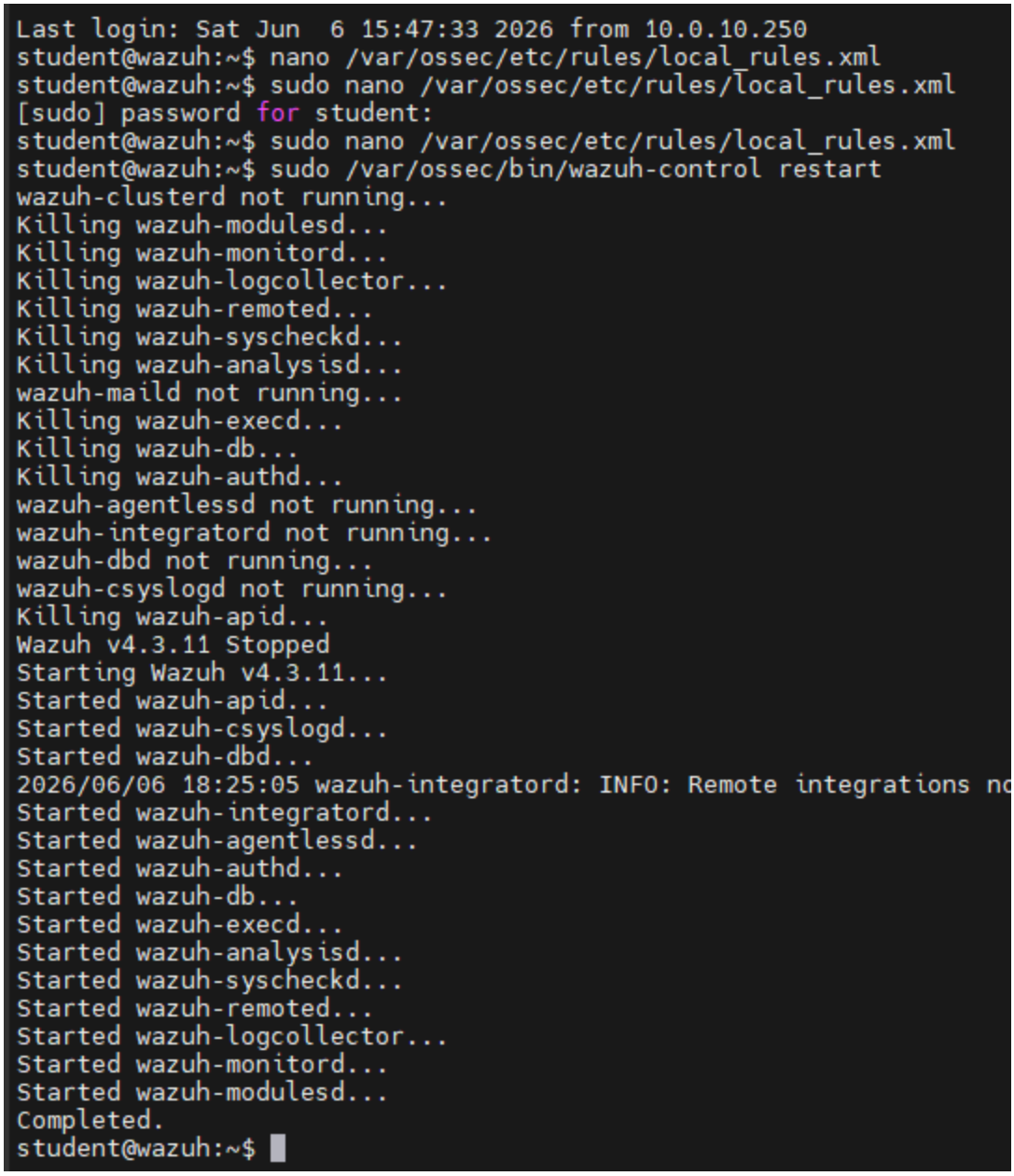
Меняем файл local_rules (уберем правило 50122 (на него было WARNING)):



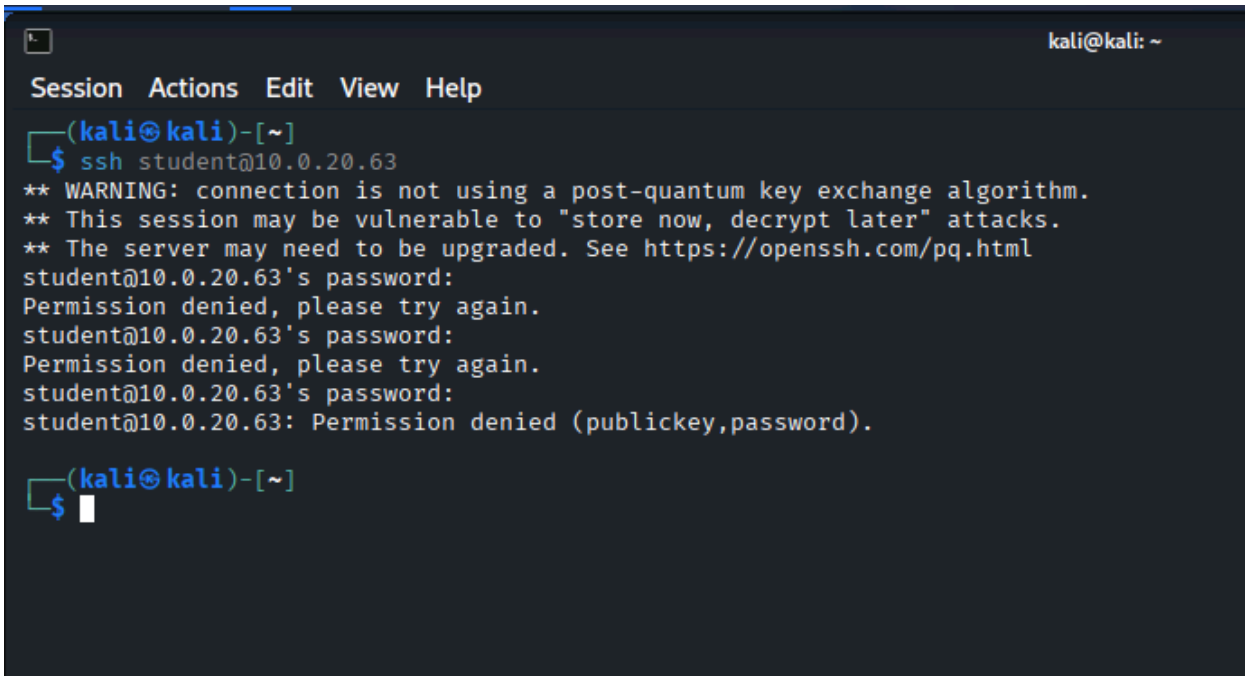
Что изменили:

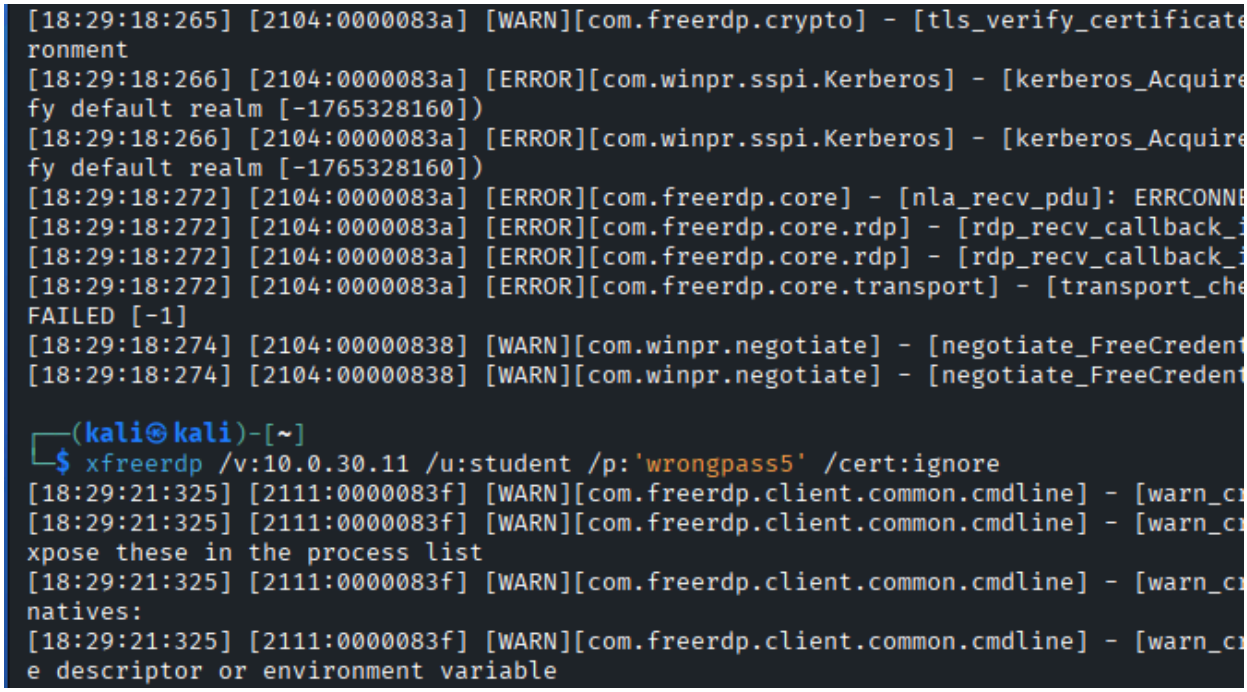
- frequency="3" вместо 5 (меньше событий нужно)
- timeframe="120" вместо 600 (2 минуты вместо 10)
- Убрали <same_user/> временно (чтобы не было проблем с группировкой)

Перезапуск менеджера

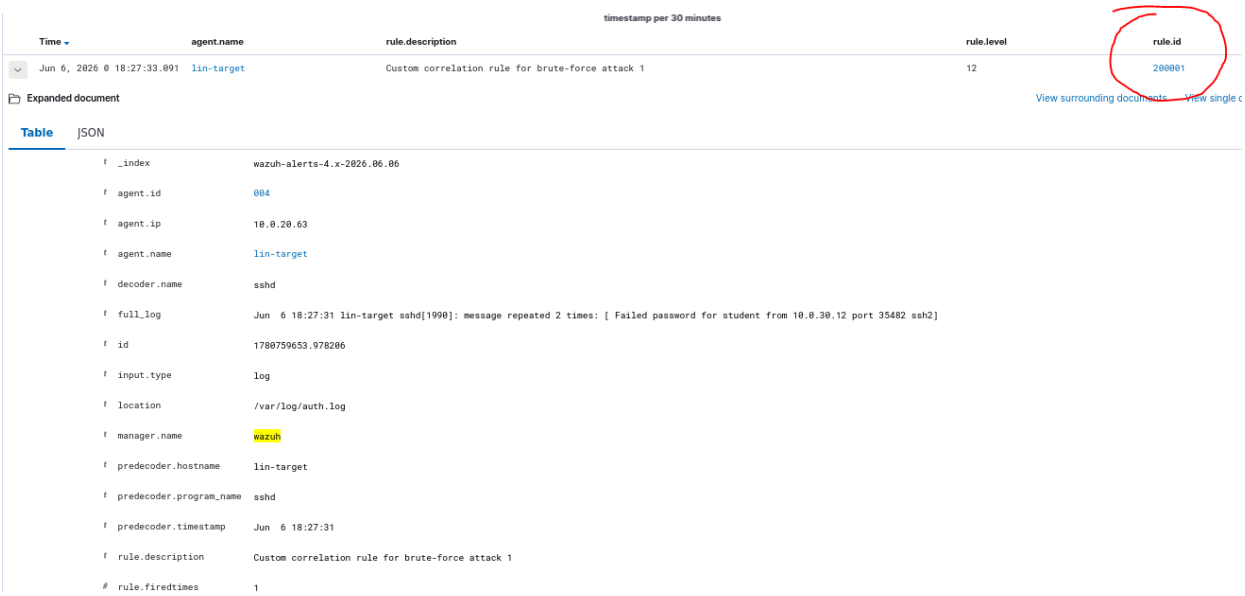


Генерируем события неправильного входа (Linux)





правило 200001 сработало



timestamp per 30 minutes

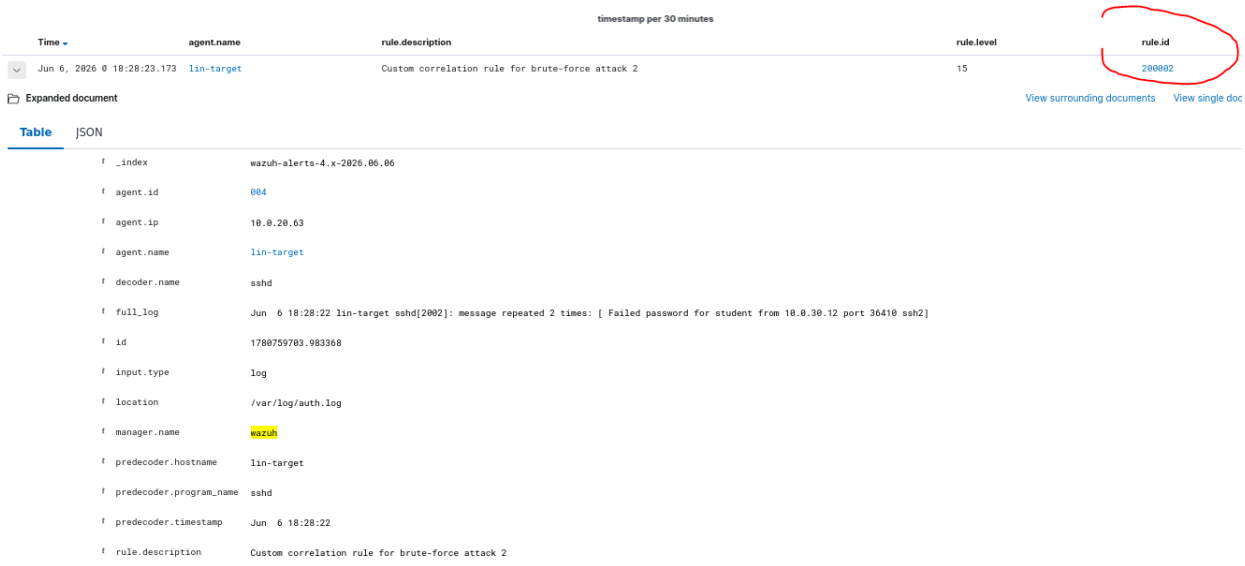
Time	agent.name	rule.description	rule.level	rule.id
Jun 6, 2026 @ 18:27:33.091	lin-target	Custom correlation rule for brute-force attack 1	12	200001

Expanded document — View surrounding documents — View single d

Table | JSON

_index	wazuh-alerts-4.x-2026.06.06
agent.id	004
agent.ip	10.0.20.63
agent.name	lin-target
decoder.name	sshd
full_log	Jun 6 18:27:31 lin-target sshd[1990]: message repeated 2 times: [Failed password for student from 10.0.30.12 port 35482 ssh2]
id	1780759653.978206
input.type	log
location	/var/log/auth.log
manager.name	wazuh
predecoder.hostname	lin-target
predecoder.program_name	sshd
predecoder.timestamp	Jun 6 18:27:31
rule.description	Custom correlation rule for brute-force attack 1
rule.firedtimes	1

Событие 200002:



timestamp per 30 minutes

Time	agent.name	rule.description	rule.level	rule.id
Jun 6, 2026 @ 18:28:23.173	lin-target	Custom correlation rule for brute-force attack 2	15	200002

Expanded document — View surrounding documents — View single doc

Table | JSON

_index	wazuh-alerts-4.x-2026.06.06
agent.id	004
agent.ip	10.0.20.63
agent.name	lin-target
decoder.name	sshd
full_log	Jun 6 18:28:22 lin-target sshd[2002]: message repeated 2 times: [Failed password for student from 10.0.30.12 port 36410 ssh2]
id	1780759703.983368
input.type	log
location	/var/log/auth.log
manager.name	wazuh
predecoder.hostname	lin-target
predecoder.program_name	sshd
predecoder.timestamp	Jun 6 18:28:22
rule.description	Custom correlation rule for brute-force attack 2

Добавим новые правила для Windows

```
<!-- ========================================== -->
<!-- Windows Brute Force Detection Rules        -->
<!-- ========================================== -->

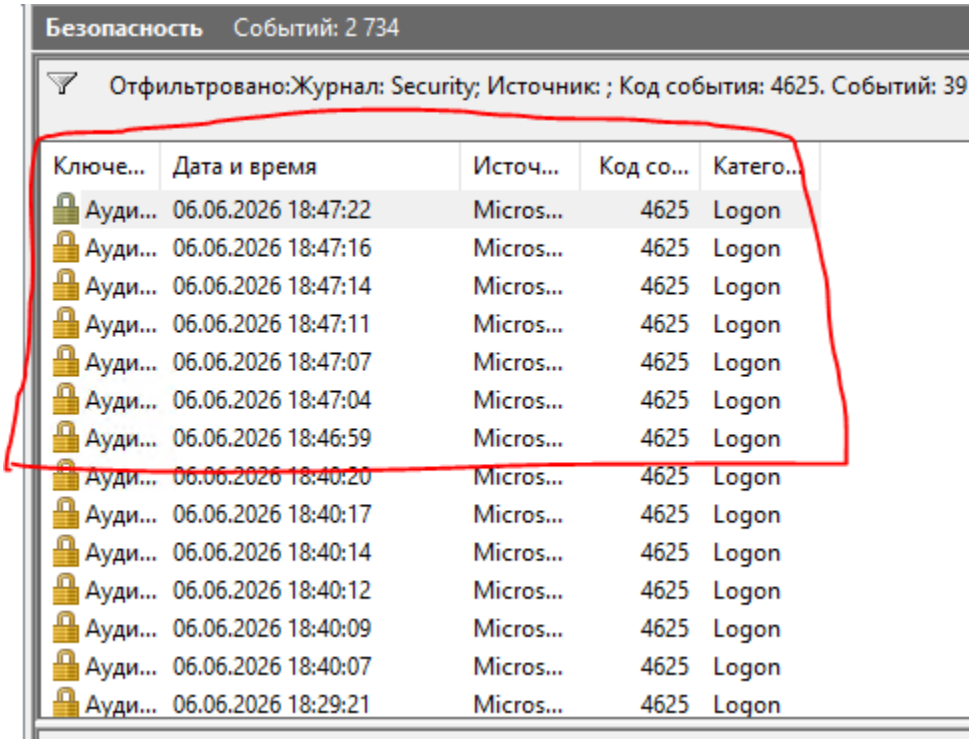
<!-- Rule 200010: Base rule - Windows logon failure -->
<rule id="200010" level="5">
  <if_sid>60122</if_sid>
  <description>Custom correlation rule for brute-force attack 0 - Windows logon failure</description>
  <group>authentication_failed,brute_force_custom,windows,</group>
  <mitre>
    <id>T1110</id>
    <id>T1110.001</id>
  </mitre>
</rule>

<!-- Rule 200011: Correlation - 5 failed logons within 10 minutes -->
<rule id="200011" level="12" frequency="5" timeframe="600">
  <if_matched_sid>200010</if_matched_sid>
  <same_srcip/>
  <description>Custom correlation rule for brute-force attack 1 - Windows brute-force detected (5 attempts, 10 min)</description>
  <group>authentication_failures,brute_force_custom,windows,</group>
  <mitre>
    <id>T1110</id>
    <id>T1110.001</id>
  </mitre>
</rule>

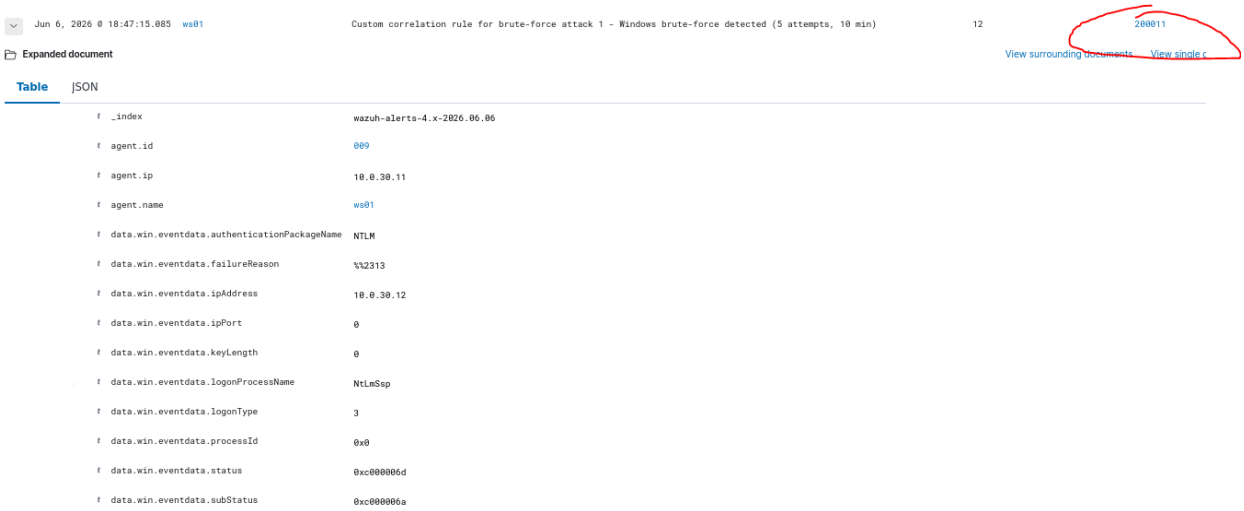
<!-- Rule 200012: Escalation - targeting privileged accounts -->
<rule id="200012" level="15">
  <if_matched_sid>200011</if_matched_sid>
  <match>admin|administrator|root</match>
  <description>Custom correlation rule for brute-force attack 2 - Windows privileged account targeted</description>
  <group>authentication_failures,brute_force_custom,windows,privileged_account,</group>
  <mitre>
    <id>T1110</id>
    <id>T1110.001</id>
    <id>T1078</id>
  </mitre>
</rule>

</group>
```

Неудачные логины в Windows (события 4625)



В веб-интерфейсе Wazuh сработали кастомные правила (brute-force detected):



Видно, что атаки проходили с адреса Kali (10.0.30.12)